



SNOWBE ONLINE

Policy# AC-5 & AC-6

Separation of Duties & Least Privilege

Your name: Jarred Ward

Separation of Duties & Least Privilege – Version 2.0

DATE: 11/10/2025

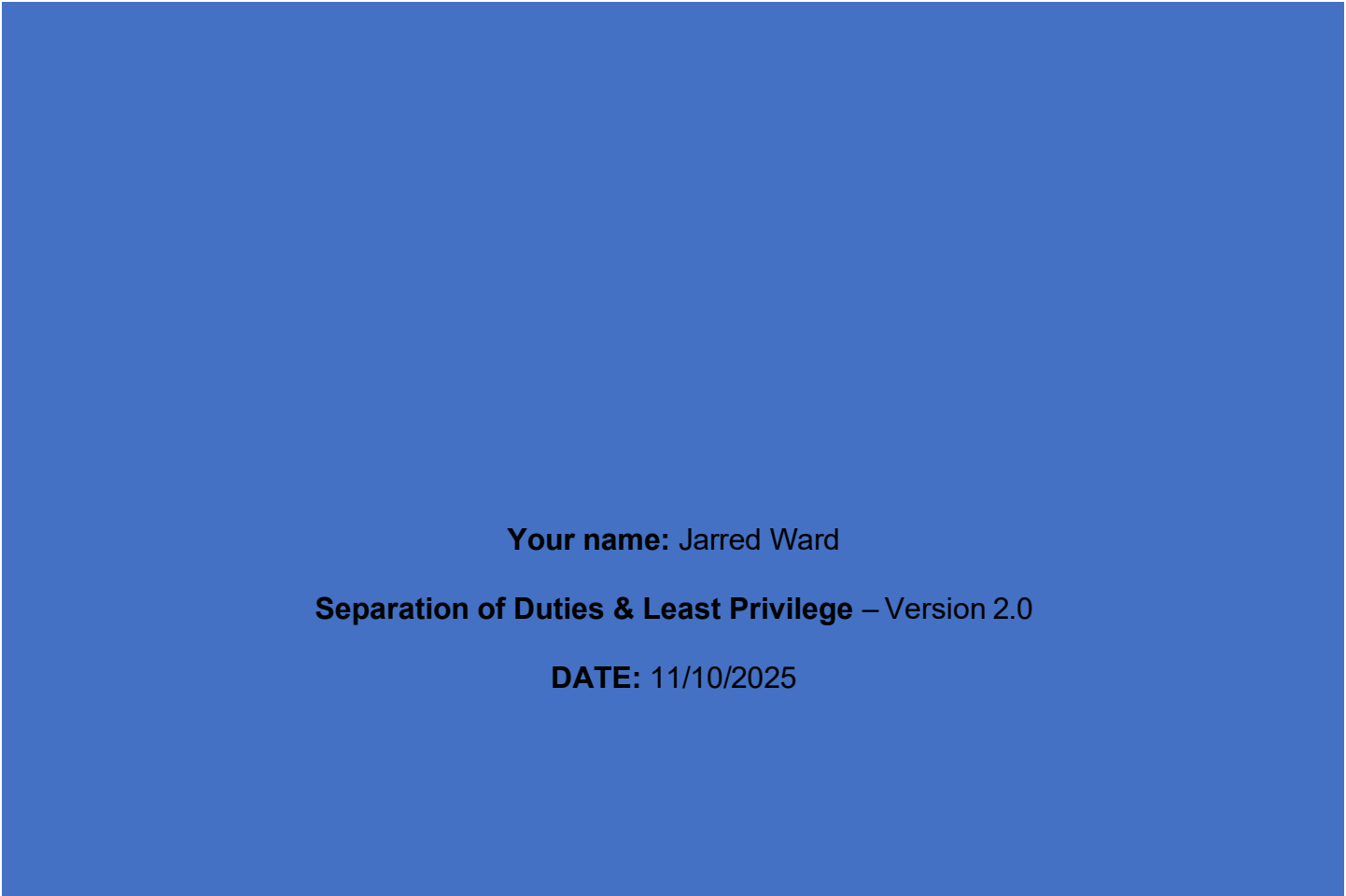


Table of Contents

PURPOSE..... 2

SCOPE..... 2

DEFINITIONS..... 2

ROLES & RESPONSIBILITIES 3

POLICY 4

EXCEPTIONS/EXEMPTIONS 5

ENFORCEMENT 5

VERSION HISTORY TABLE 5

CITATIONS 6

Purpose

SnowBe Online implements separation of duties and least privilege to reduce the risk of fraud, configuration errors, and unauthorized access to customer and payment data across its AWS platform, office systems, and retail environments. This policy defines how access is requested, approved, provisioned, reviewed, and revoked so that each employee performs only the tasks necessary for their job. It ensures critical business and system operations are divided among distinct roles to maintain accountability and compliance with PCI DSS and NIST 800-53 requirements.

Scope

This policy applies to all SnowBe employees, contractors, and vendors who access SnowBe information systems, including on-premise servers, AWS-hosted applications, POS terminals, and remote VPN sessions. It governs account privileges, administrative access, and operational roles that interact with customer data, payment processing, or internal business platforms.

Definitions

Access Creep

The gradual accumulation of privileges beyond what a user's current job requires.

Conflict of Interest

A condition where a combination of privileges enables a user to execute and approve the same high-risk transaction.

Dual Control

A safeguard requiring two authorized individuals to complete a critical operation.

Least Privilege

Granting only the minimum access necessary to perform assigned duties.

Privileged Account

An account with elevated permissions to manage configurations or data.

Separation of Duties

Dividing sensitive tasks among different roles to prevent abuse or undetected error.

Toxic Combination

A set of permissions that, if combined, could allow unauthorized or fraudulent activity.

Roles & Responsibilities

Application Owner

Defines application-specific roles, approval workflows, and toxic combinations that must be avoided. They are also responsible for reviewing these definitions regularly to ensure they continue to meet SnowBe's operational and compliance needs.

Audit Team

Independently reviews and verifies that separation-of-duties and least-privilege principles are implemented correctly across systems. The audit team documents findings and provides recommendations to improve compliance and control strength.

Chief Information Security Officer (CISO)

The CISO oversees SnowBe Online's information security strategy, ensuring alignment with business goals, NIST 800-53 controls, and PCI DSS compliance. This role leads risk management, approves major security initiatives, and reports the company's security posture to executive leadership.

GRC Team

Maintains this policy, defines toxic combinations, and ensures enforcement across all departments. The GRC team coordinates quarterly access reviews and manages remediation efforts for violations.

HR

Provides timely notifications of all hires, transfers, and terminations that affect access provisioning or de-provisioning. The HR department coordinates closely with IT to ensure that access changes occur promptly and accurately.

IT Security Manager

The IT Security Manager implements and enforces security controls across SnowBe's AWS and on-premise systems. This role manages daily operations, coordinates vulnerability management, and ensures policy compliance through training and incident oversight.

IT Service Desk

Grants user access only after receiving documented managerial approval and verified authorization. It also manages emergency privilege elevations and ensures they are time-bound and fully logged.

User

Requests only the access needed to perform assigned duties and uses non-privileged accounts for daily work. Each user must report any inappropriate or excessive access to their manager or the Security team immediately.

Policy

SnowBe shall establish and maintain role-based access controls that implement separation of duties and least privilege across all systems and applications. Each business and technical function must have clearly defined roles that prevent a single user from executing and approving the same high-risk transaction or system change. Access requests must be reviewed and approved by the user's manager and verified by the Security team prior to provisioning. All administrative accounts shall be unique, auditable, and restricted to authorized personnel with documented business justification. Users must employ non-privileged accounts for daily operations and elevate privileges only when necessary, using approved secure authentication methods and encrypted sessions. All privileged actions shall be conducted through authorized channels, and the activity shall be logged, monitored, and reviewed for accuracy and compliance.

Access certifications shall occur quarterly for privileged accounts and semi-annually for standard accounts. Access rights for employees who change roles or depart the company must be adjusted or revoked immediately to prevent access creep or unauthorized data exposure. Violations of least-privilege or separation-of-duties requirements must be investigated and remediated without delay. Acceptable behavior includes using non-privileged accounts for daily work, requesting access through approved channels, and maintaining separation between development, testing, and production activities. Unacceptable behavior includes sharing privileged credentials, granting access without documented approval, performing administrative actions with unapproved accounts, or modifying system configurations outside of assigned responsibilities. Circumventing access controls or maintaining unused privileged accounts is strictly prohibited.

- **AC-5 Separation of Duties** – Ensures critical business and technical functions are divided among multiple authorized roles to prevent single-point compromise.
- **AC-6 (1) Authorize Access to Security Functions** – Restricts security changes to approved administrators only, preventing unintentional weakening of defenses.
- **AC-6 (2) Non-Privileged Access for Non-Security Functions** – Limits business users from altering system-level files, protecting AWS servers and desktops from unauthorized changes.
- **AC-6 (3) Network Access to Privileged Commands** – Requires privileged commands to be executed only via secure, logged VPN or encrypted consoles with authentication.
- **AC-6 (4) Separate Processing Domains** – Isolates administrative processes from daily operations, maintaining integrity across accounting, order management, and vendor systems.
- **AC-6 (5) Privileged Accounts** – Mandates unique administrative accounts for each user to improve traceability and accountability.

Exceptions/Exemptions

Requests for exceptions must be submitted in writing to SnowBe Online's IT Security Manager for review and approval. Each request must include the business justification, defined scope, duration, and any compensating controls that will be applied. All approved exceptions will be formally documented, reviewed periodically for continued appropriateness, and remain valid for no longer than one year unless re-evaluated and re-approved.

Enforcement

Failure to follow this policy may result in disciplinary action, beginning with a verbal warning and escalating to written notice, suspension of system access, or termination of employment. Contractors and vendors who violate SnowBe Online's security or compliance requirements may have their access revoked or contracts terminated. Intentional or severe violations, especially those involving customer data or payment systems, may lead to termination and potential legal or regulatory action under applicable laws.

Version History Table

Version #	Implementation Date	Document Owner	Approved By	Description
1.0	11/3/2025	Jarred Ward	IT Security Manager	Original Draft
2.0	11/10/2025	Jarred Ward	IT Security Manager	Updated Access Control Policy

Citations

Brookhaven National Laboratory - <https://www.bnl.gov/cybersecurity/policies/separation-of-duties.php>
(Used for Purpose, Scope, Policy).

United Nations Population Fund - https://www.unfpa.org/sites/default/files/admin-resource/FINA_Segregation_of_Duties.pdf – (Used for Definitions, Roles & Responsibilities).

U.S. Department of Education - <https://www.ed.gov/sites/ed/files/fund/contract/about/acs/2021-separation-of-duties.pdf> (Used for Enforcement, Exceptions/Exemptions).